

Remaining actions

Everything in the image and content audit that could be completed in code has been. This is what is left: work only you can do, plus two design items deliberately left for review. Printed to be worked through in one sitting.

Publisher Oak and Main Developers LLC 2108 N St., Sacramento, CA 95816	Shipped this pass 6 commits, 19 pages 118 tests, browser QA 25/25	Branch claude/glp1-fund-frontend-audit-upw4ec
---	--	---

A. Blocks launch

The site now collects personal data and promises things that need these to be true. Do these before the site takes another signup.

- ☐ **1. Create the `contact@glp1-fund.com` mailbox**

You gave an entity and an address but no email, so I wired a placeholder on your own domain rather than invent a third-party address or publish your personal Gmail. It is now printed on four pages as the corrections channel, the privacy contact and the CCPA/CPRA request route. Until the mailbox exists, those pages promise a channel that bounces.

`public/engine/config.js` → `PUBLISHER.email`

If you would rather use a different address, change that one constant and rebuild. It flows everywhere.
- ☐ **2. Set the `ALERTS_SECRET` binding in Cloudflare**

The unsubscribe endpoint signs its links with HMAC so a stranger cannot remove someone else's address. Without the secret it fails closed: unsubscribe returns an error rather than deleting anything. Signup is unaffected, so this will not look broken until someone tries to leave.

Cloudflare Pages → Settings → Functions → Environment variables → `ALERTS_SECRET`

Any long random string. Generate with: `openssl rand -hex 32`
- ☐ **3. Have a lawyer read `/privacy/` and `/terms/`**

Both are written against what the code actually does rather than from a template: the privacy policy names all five stored fields, both KV locations, the retention window and the CCPA/CPRA and GDPR rights. That makes them accurate, not reviewed. A California LLC collecting email addresses on a health-adjacent site should have a professional read them once.

`public/privacy/index.html` and `public/terms/index.html`

Both are generated. Edit the builders in `tools/build-pages.mjs`, not the HTML, then rebuild.
- ☐ **4. Decide the data retention period**

I set 730 days after last interaction and published it as a promise. It is a reasonable default, not your decision. If you want a different window, change it before anyone reads the policy and relies on it.

`public/engine/config.js` → `DATA_RETENTION_DAYS`

B. Before the first alert email goes out

The list can accept signups today. It cannot lawfully send yet.

☐ 5. Build the send path, with the unsubscribe link in it

There is no email-sending code anywhere in the project. The unsubscribe endpoint and its token signer are built and tested, but nothing generates the links yet. CAN-SPAM requires a working opt-out in every message, and the alerts page promises one-click.

`signUnsubscribe(email, env.ALERTS_SECRET)` in `functions/api/alerts.js`
link: `https://glp1-fund.com/api/alerts?unsubscribe=EMAIL&t=TOKEN`

Also set the List-Unsubscribe and List-Unsubscribe-Post headers so one-click works in Gmail and Apple Mail. The endpoint already answers the RFC 8058 POST.

☐ 6. Add a physical postal address to the email footer

CAN-SPAM requires it in the message itself, not only on the website. Your address is already in config and renders on four pages, so it is a copy-paste into the template.

`PUBLISHER_ADDRESS` in `public/engine/config.js`

C. Design work left for your review

I could have shipped these. I chose not to, because both are judgment calls about how the site looks rather than defects, and you said the rest of the audits land tonight.

☐ 7. The introductory-pricing cliff diagram

The caveat now renders as a weighted warning block on all five pages whose data carries it, which was the urgent half. The audit also proposed drawing the cliff: what you pay at first, what you pay after, and what triggers the change. That is a genuine design decision and it sits on pages about money, so it wants your eye.

Prompt P3 in `docs/image-content-audit-2026-08.md`

Constraints are in the prompt: inline SVG only, HTML labels not SVG text, seven-element vocabulary.

☐ 8. Empty-state visual treatment

All 45 rows are null, so the no-verified-price state is the site's dominant visual state and still renders as grey blocks. The homepage now states the position in plain type above it, which was the worst of it. The block itself is authored in five places across three files, so redesigning it is a real change rather than a tweak, and worth doing deliberately.

`app.js:66,72,157` `render.js:231` `build-pages.mjs:362`

Prompt P5. Do not change ad-slot dimensions: they are CLS controls gated by `qa.mjs`.

D. Blocked, not forgotten

☐ 9. Verify actual prices

Every one of the 45 figures is unverified because this build's network refuses outbound connections to every primary source: `fda.gov`, `cms.gov`, `medicare.gov`, `trumprx.gov` and all Eli Lilly and Novo Nordisk domains. QA confirms 8 of 8 source URLs unreachable for that reason, not because they are broken. Nothing in code fixes this. It needs a network that can reach them.

When the first real price lands, test 42 and test 71 must be relaxed. The new provenance gate (`test/provenance.test.js`) then becomes the real check and needs no change.

One thing worth protecting

Everything above adds to the site. Nothing above softens it. The refusal to publish a figure that has not been read from a primary source is the most valuable thing this project has, and it is now enforced by a test that keeps working after you start publishing prices rather than one that expires on that day. The fastest way to undo this pass would be to fill the silence with confident numbers.